

Ransomware

A Comprehensive Overview of the Threat Landscape

IT Security – Educational Presentation

March 1, 2026

Agenda

What is Ransomware?

History and Evolution

Types of Ransomware

Extortion Models

The Ransomware Economy

Attack Lifecycle (Cyber Kill Chain)

Detection and Defense

Legal and Ethical Dimensions

Future Trends and Challenges

Conclusion

What is Ransomware?

Definition

Ransomware is a type of malicious software that restricts access to a computer system or its data – typically through **encryption** – and demands a **ransom payment** for restoration.

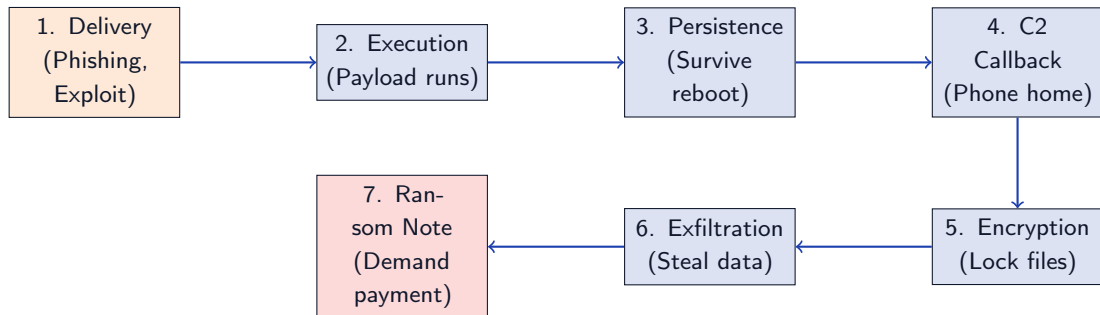
Core Characteristics

- Denies access to files or systems
- Demands payment (cryptocurrency)
- Uses strong encryption algorithms
- Often includes a deadline/timer

Typical Targets

- Hospitals & healthcare
- Government agencies
- Educational institutions
- Critical infrastructure
- Small/medium businesses

How Ransomware Works – High-Level Overview



History and Evolution

The Origins: AIDS Trojan (1989)

The first known ransomware:

- Created by Dr. Joseph Popp
- Distributed via 20,000 floppy disks at a WHO conference
- Labeled “AIDS Information – Introductory Diskette”
- Encrypted file names on the C: drive after 90 reboots
- Demanded \$189 sent to a PO Box in Panama
- Used simple symmetric cryptography (easily reversible)

AIDS Trojan (1989)

Floppy disk distribution

Symmetric encryption

\$189 ransom via mail

Easily defeated

Evolution Timeline



Key trend: From hobbyist experiments → organized cybercrime → state-sponsored operations

Landmark Attacks

WannaCry (May 2017)

- Exploited EternalBlue (NSA-leaked SMB vulnerability)
- Infected 230,000+ computers in 150 countries
- Hit NHS (UK), FedEx, Renault, Deutsche Bahn
- Caused \$4–8 billion in damages
- Accidentally stopped by a kill switch domain registration
- Attributed to North Korea (Lazarus Group)

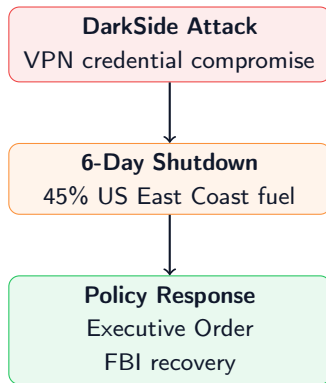
NotPetya (June 2017)

- Disguised as ransomware, actually a wiper
- Distributed via Ukrainian tax software update (MeDoc)
- Spread globally via EternalBlue + credential harvesting
- Maersk: rebuilt entire IT (45,000 PCs, 4,000 servers)
- Total damages: \$10+ billion
- Attributed to Russian military (GRU)

Colonial Pipeline (2021)

The attack that changed policy:

- DarkSide ransomware group attacked Colonial Pipeline
- Pipeline supplies 45% of US East Coast fuel
- Shut down for 6 days (May 7–12, 2021)
- Caused fuel shortages, panic buying, price spikes
- Company paid \$4.4 million in Bitcoin
- FBI recovered \$2.3 million (63.7 BTC)



Impact

Led to US Executive Order on Cybersecurity. Ransomware elevated to national security threat. Dark-

Types of Ransomware

Fundamental Classification

1. Crypto-Ransomware

- **Encrypts** user files (documents, images, databases)
- System remains functional
- Uses strong encryption (AES, RSA, ChaCha20)
- Recovery without key is practically impossible
- **Examples:** CryptoLocker, LockBit, BlackCat

2. Locker-Ransomware

- **Locks** the entire system (screen lock)
- Files themselves are *not* encrypted
- Often impersonates law enforcement (“FBI virus”)
- Easier to remove (boot from USB, safe mode)
- **Examples:** WinLocker, Police Ransomware

Today, **crypto-ransomware** dominates (>95% of incidents). Locker variants are largely obsolete.

Modern Variants and Tactics

3. Wipers (Destructive)

- Disguised as ransomware but data is irrecoverable
- Goal: destruction, not profit
- Often state-sponsored (NotPetya, WhisperGate)
- No functional decryption mechanism exists

4. Leakware / Doxware

- Threatens to **publish** stolen data
- Even if backups exist, victim still pressured
- Regulatory fines (GDPR) add leverage
- Data is often sold on darknet regardless

5. RaaS (Ransomware-as-a-Service)

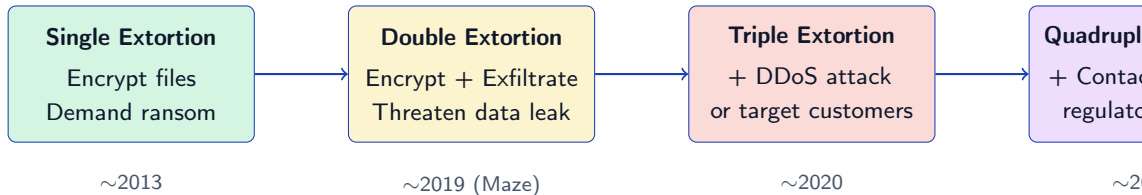
- Subscription-based model for affiliates
- Provider handles malware development, C2 infra, negotiation
- Affiliate handles initial access and deployment
- Revenue split: typically 70/30 or 80/20
- Lowered barrier to entry massively

6. Intermittent Encryption

- Only encrypts parts of each file (e.g., every other block)
- Files still unusable but encryption is 5–10x faster

Extortion Models

The Evolution of Extortion



Key Trend

Even organizations with perfect backups can be extorted. Data theft and reputational damage create pressure independent of encryption.

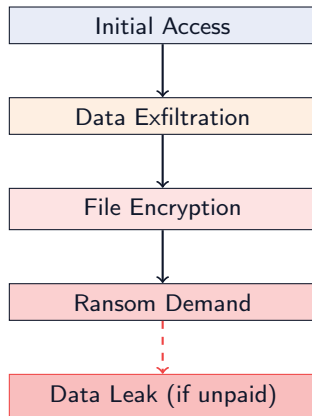
Double Extortion in Detail

Pioneered by Maze (Nov 2019):

1. Attacker gains initial access
2. **Exfiltrate** sensitive data to attacker-controlled servers
3. **Encrypt** files on victim network
4. Demand ransom for decryption key
5. If victim refuses: publish stolen data on **leak site**

Why this is devastating:

- Backups don't help against data leaks
- GDPR fines can exceed ransom amount
- Competitive intelligence exposure



The Ransomware Economy

Ransomware-as-a-Service (RaaS)

RaaS transforms ransomware from individual attacks into a **professional shadow economy**:

Initial Access Brokers

Specialists who sell network access to victim organizations.

Methods:

- Phishing campaigns
- Exploit kits
- Stolen VPN credentials
- Insider recruitment

Price: \$500–\$100,000+

RaaS Operators

Develop and maintain the malware platform:

- Ransomware binary
- C2 infrastructure
- Negotiation portals
- Leak sites
- 24/7 “support”

Cut: 20–30% of ransom

Affiliates

The operators who execute attacks:

- Buy access
- Deploy ransomware
- Handle negotiation
- Collect payment
- Vary in skill level

Cut: 70–80% of ransom

Financial Impact – Global Scale

Estimated Global Damages

2017: **\$5B**

2019: **\$11.5B**

2021: **\$20B**

2024: **\$42B**

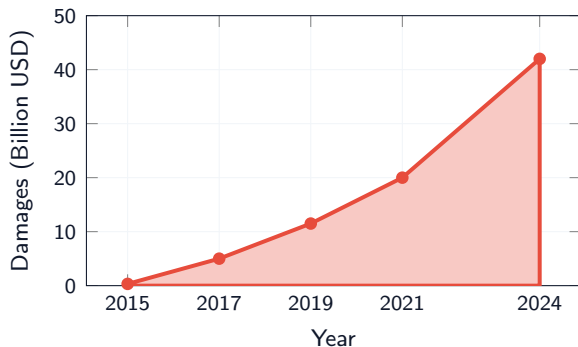
2031: **\$265B (est.)**

+740% increase in 7 years

Average ransom payment in 2024:

\$2.73 million (Sophos)

Average downtime: **24 days**



Professionalization: LockBit Case Study

LockBit exemplifies the professionalization of ransomware operations:

Business Features

- Affiliate portal with dashboard
- Bug bounty program for their malware
- “StealBit” custom exfiltration tool
- Automatic negotiation via Tor
- Multiple encryption modes (fast, full, intermittent)
- Multi-OS support (Windows, Linux, VMware ESXi)

LockBit Bug Bounty

“Locker Bugs: Any errors during encryption ... that lead to corrupted files or to the possibility of decrypting files without getting a decryptor.”

Rewards range from \$1,000 to \$1,000,000 for vulnerabilities in their infrastructure.

Takedown: Feb 2024

Operation Cronos (FBI + NCA + Europol) seized LockBit infrastructure. Group at-

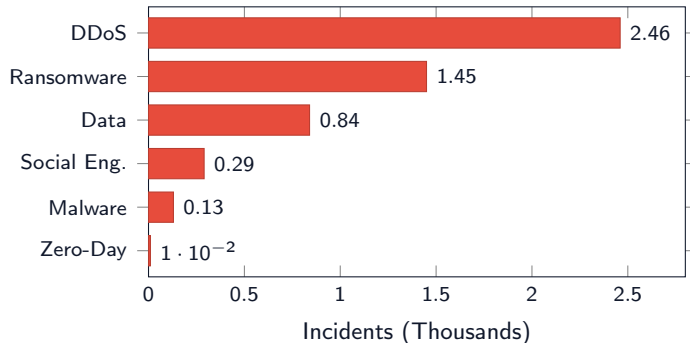
ENISA Threat Landscape 2024

Top EU Cyber Threats:

1. DDoS/RDoS (46.31%)
2. Ransomware (27.33%)
3. Data Breaches (15.87%)
4. Social Engineering (5.37%)
5. Malware (2.45%)
6. Zero-Day (0.11%)

Ransomware: 2nd largest threat in Europe

Source: ENISA Threat Landscape Report 2024



Attack Lifecycle (Cyber Kill Chain)
